Information Security Policy

1. Purpose

The purpose of this **Information Security Policy** is to define **Amman National Bank's** high-level commitment to protecting its **information assets**, **banking systems**, **customer data**, and **critical technology services**.

This policy supports the implementation and operation of the bank's **Information Security Management System (ISMS)** and provides the foundation for protecting the **confidentiality**, **integrity**, and **availability** of information within the approved **ISMS scope**.

2. Scope

This policy applies to all **systems**, **information**, **processes**, **people**, and **supporting services** included within the approved **ISMS scope** of **Amman National Bank**.

The scope includes the following areas:

- **Core Banking**
- **Digital Banking**
- **Payments**
- **ATM Services**
- **Identity and Access Management**
- **Security Monitoring**
- **Backup**
- **Disaster Recovery**

This policy applies to **employees**, **contractors**, **third-party service providers**, and any authorized users who access, manage, process, store, transmit, monitor, or support information and systems within the **ISMS scope**.

3. Policy Commitment

Amman National Bank is committed to protecting its **information assets** and **critical banking services** from unauthorized access, disclosure, alteration, loss, misuse, disruption, or destruction.

The bank will maintain an **Information Security Management System (ISMS)** to manage information security risks, support compliance with applicable **legal**, **regulatory**, and **contractual requirements**, and protect the interests of customers, employees, regulators, business partners, and other relevant interested parties.

The bank recognizes that information security is essential to maintaining **customer trust**, **financial integrity**, **regulatory compliance**, **business continuity**, and **operational resilience**.

4. Information Security Principles

Amman National Bank will apply the following information security principles:

4.1 Confidentiality

Information must be protected from **unauthorized access** or **unauthorized disclosure**.

Access to sensitive information, including **customer data**, **financial records**, **authentication data**, **payment instructions**, **security logs**, and **backup data**, must be limited to authorized users based on business need.

4.2 Integrity

Information and systems must be protected from **unauthorized modification**, **inaccurate processing**, or **unauthorized manipulation**.

The bank will apply appropriate controls to help ensure the accuracy, completeness, and reliability of banking data, payment transactions, system records, and security logs.

4.3 Availability

Critical banking systems and services must be available when required to support business operations and customer services.

The bank will maintain appropriate **backup**, **recovery**, **monitoring**, and **disaster recovery** capabilities to reduce the impact of service disruption, data loss, system failure, ransomware, or major incidents.

4.4 Least Privilege

Users must only be granted the minimum level of access required to perform their approved job responsibilities.

Privileged access must be controlled, approved, monitored, and reviewed regularly.

4.5 Need-to-Know

Access to sensitive information must be granted only when there is a valid business need.

Employees, contractors, and third parties must not access, use, copy, share, or disclose information unless it is required for their authorized duties.

4.6 Data Classification and Secure Handling

Information must be classified and handled according to the bank's approved **Data Classification Model**.

Sensitive information must be stored, transmitted, retained, shared, and disposed of securely based on its classification level, business value, and regulatory impact.

4.7 Compliance

Information security activities must support compliance with applicable **legal**, **regulatory**, **contractual**, and **industry requirements**.

This includes requirements related to customer data protection, payment security, cyber incident response, audit evidence, supplier security, and operational resilience.

4.8 Risk-Based Security

Information security decisions must be based on risk.

The bank will identify, assess, treat, monitor, and review information security risks that may affect the confidentiality, integrity, availability, compliance, or resilience of in-scope information and systems.

4.9 Continual Improvement

The bank will review and improve its information security practices over time based on risk assessment results, incidents, audit findings, regulatory changes, technology changes, threat landscape changes, and management decisions.

5. Roles and Responsibilities

5.1 Board of Directors

The **Board of Directors** provides governance oversight and ensures that information security risks are considered as part of the bank's overall risk and governance responsibilities.

5.2 Senior Management

Senior Management is responsible for supporting the implementation and continual improvement of the **ISMS**, providing appropriate resources, approving policies, assigning responsibilities, and supporting risk-based decision-making.

5.3 Information Security / Cybersecurity Function

The **Information Security / Cybersecurity Function** is responsible for coordinating information security activities, supporting risk assessment, defining security requirements, monitoring security events, supporting incident response, and maintaining security-related documentation and evidence.

5.4 IT Department

The **IT Department** is responsible for implementing and maintaining technical controls, managing systems and infrastructure, supporting access control, backup, change management, monitoring, and secure operation of in-scope technology services.

5.5 Compliance and Risk Management Functions

The **Compliance** and **Risk Management** functions are responsible for supporting regulatory alignment, risk assessment, risk treatment, compliance monitoring, and reporting of relevant information security risks and obligations.

5.6 Internal Audit

Internal Audit is responsible for independently reviewing the design and effectiveness of information security controls, identifying gaps, and reporting audit findings and improvement opportunities.

5.7 Employees, Contractors, and Third Parties

All **employees**, **contractors**, and **third parties** are responsible for following this policy, protecting information assets, using access rights appropriately, reporting security incidents or suspicious activities, and complying with applicable information security procedures.

6. Compliance and Exceptions

Compliance with this **Information Security Policy** is mandatory for all users, systems, processes, and third parties within the approved **ISMS scope**.

Any violation of this policy may result in corrective action, access restriction, disciplinary action, contractual action, or legal action, depending on the nature and severity of the violation.

Any exception to this policy must be formally documented, justified, risk-assessed, approved by authorized management, and reviewed periodically. Exceptions must not create unacceptable risk to the bank, customers, regulators, or in-scope critical banking services.

7. Review and Approval

This **Information Security Policy** must be reviewed at least annually or when significant changes occur, including changes to business operations, technology architecture, regulatory requirements, threat landscape, risk assessment results, or the approved **ISMS scope**.

This policy must be approved by **Senior Management** and communicated to relevant employees, contractors, and third parties within the **ISMS scope**.

Document Owner: Information Security / Cybersecurity Function

Approved By: Senior Management

Review Frequency: Annual or upon significant change

Status: Draft for ISMS Project Documentation